

# Task Solution: Threat Model and Secure Configuration

Target Application: Standard Web Application (User Login & Profile Management System)

## 1. Threat-Model Diagram Components (Threat Model Diagram)

The Threat Model Diagram illustrates the components and interactions of the system, identifying potential threats and attack vectors.

- Users (Actors):** Regular User (Authenticated User) and Admin (Privileged User).
- Trust Boundaries (Interfaces):** Client-side Browser and Web Server (HTTPS), Web Server and Database Server (HTTPS).
- Data Flows (Data):** HTTPS (Encrypted Data), Session Tokens (Session Management).
- External Dependencies:** Auth0 (OAuth) and Stripe (Payment Gateway).

## 2. STRIDE Threat Analysis (STRIDE Threat Model)

- Spoofing (Impersonation):** An attacker impersonates a legitimate user (Session Hijacking) to access sensitive data.
- Tampering (Data Manipulation):** An attacker modifies data in transit (e.g., session tokens) to gain unauthorized access.
- Repudiation (Denial of Action):** An attacker denies performing an action (e.g., login attempt) after it has been recorded.
- Information Disclosure:** An attacker gains access to sensitive information (e.g., user credentials, session tokens) stored or transmitted by the system.
- Denial of Service (DoS):** An attacker floods the system with malicious requests (Malicious Requests) to disrupt service.
- Elevation of Privilege:** An attacker exploits a vulnerability (e.g., IDOR) to gain access to higher privileges than intended.

## 3. Risk Register (Risk Register)

The Risk Register summarizes the identified threats and their associated risk levels.

| Threat Case (Threat Case)              | Severity | Impact | Risk Rank (Risk Rank) |
|----------------------------------------|----------|--------|-----------------------|
| SQL Injection (Information Disclosure) | Medium   | High   | High (High)           |

